SAFETY 4.0 · GÜNCEL KONULAR PROJESİ · HAFTA 6

CRA Incident Simulation

CEOTHERM Homojenizasyon Tesisi

Föy	Çıktı	Makine
Lab 6 · CRA Incident Simulation	Incident Workflow → EP 13 Incident Response	Fırın + soğutma kabini + biyet transfer arabası

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Senaryo (makinemize uyarlandı)

Saat 10:15. Servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir. Föydeki "ışık perdesi" yerine bizim makinemizde kritik olan emniyet parametreleri henüz doğrulanmadı: yakma emniyeti (pre-purge, alev denetim süresi), limit sıcaklık ve transfer arabası alan koruması. Makine çalışıyor, fırında bir şarj var. Vardiya sorumlusu sizsiniz.

Senaryo kurgudur. Emniyet parametreleri ve servis hesabı yapısı Hafta 1–2 varsayımlarıyla aynıdır.

Görev – Zaman çizgisini doldurun

1. 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

- **Kimi:** OT güvenlik/bakım sorumlusu ve üretim amiri. Küçük tesiste en yetkili teknik kişi + yönetici.

İlk üç eylem:

- **1) Hesabı dondur:** Şüpheli servis hesabının erişimini hemen kes (uzak erişimi kapat). Yeni girişleri durdur.
- **2) Makineyi değerlendir:** Şarjı durdurmadan önce emniyet durumunu kontrol et. Anormal bir komut/hareket var mı? Şüphe varsa güvenli duruma al.
- **3) Kanıtı koru:** Hiçbir log silme, cihazı sıfırlama. Mevcut durumu olduğu gibi dondur (ekran görüntüsü, log yedeği).

2. İlk 2 saat: Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

Emniyet güvende mi (föydeki "egzoz güvende mi"nin bizdeki karşılığı):

- Yakma emniyeti parametreleri değişmiş mi: pre-purge süresi, alev denetim süresi, limit sıcaklık bilinen güvenli değerlerde mi?
- Transfer arabası alan koruması ve acil stop hâlâ tetikleniyor mu (fonksiyon testi)?
- Değişiklik şüphesi varsa: emniyet parametrelerini doğrulanmış yedekle karşılaştır, gerekirse güvenli duruma al.

Hangi kanıt korunur: PLC değişiklik logları, uzak erişim/oturum kayıtları, HMI olay kaydı, firmware/parametre sürüm bilgisi, zaman damgaları. Hepsi değiştirilmeden yedeklenir.

Hangi hesap kapatılır: Ele geçirilen servis hesabı kalıcı kapatılır; parolası sıfırlanır. Aynı parolayı paylaşan başka hesap varsa onlar da. Kişisel hesaplar MFA ile yeniden doğrulanır.

3. 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

CRA'da aktif istismar edilen bir açık için 24 saat içinde erken uyarı verilir. Hazır olması gereken:

- Ne zaman, neyin fark edildiği (03:00 girişi, 10:15 tespiti)
- Hangi sistem/makine etkilendi (homojenizasyon hattı, hangi PLC)
- İlk değerlendirme: emniyet etkilendi mi, üretim durdu mu
- Alınan ilk önlemler (hesap donduruldu, erişim kapatıldı)

Bu aşamada her şeyin kesin olması gerekmez; amaç yetkiliyi erkenden haberdar etmek.

Kim bildirir: Bu bilgiler üreticiye (Ceotherm) iletilir. CRA bildirimini üretici yapar. İşletici kendi kapsamındaki ayrı yükümlülükleri (ör. NIS2) ayrıca değerlendirir.

4. 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

Başlık	İçerik	Kim
Kök neden	Servis hesabı nasıl ele geçirildi (zayıf parola? MFA yokluğu? sızdırılmış kimlik?)	OT güvenlik sorumlusu
Etki	Hangi parametreler değişti, emniyet/üretim ne kadar etkilendi, ürün kaybı var mı	Üretim + bakım
Önlem	Hesap kapatıldı, MFA zorunlu kılındı, uzak erişim DMZ'ye alındı, parametreler doğrulandı	OT güvenlik + yönetim
Bildirim (işletici → üretici)	Olay ve etkilenen bileşen Ceotherm'e bildirilir	Yönetim / uyum sorumlusu
Bildirim (üretici → yetkili kurum)	CRA kapsamında 24s erken uyarı ve 72s bildirim	Ceotherm (üretici)

5. 14 gün — son rapor: Hangi loglar / kayıtlar korunmuş olmalı?

- Uzak erişim ve oturum kayıtları (giriş zamanı, konum, kim)
- PLC parametre değişiklik logları ve eski/yeni değerler
- HMI olay ve alarm kayıtları
- Firmware / parametre sürüm geçmişi
- Şarj sıcaklık-zaman kayıtları (o vardiyadaki ürün için)
- Müdahale sırasında alınan tüm aksiyonların zaman damgalı kaydı

Bu yüzden Hafta 2 ve 4'te "tam oturum kaydı" şart dedik: kayıt yoksa 14 günlük son rapor yazılamaz, kök neden bulunamaz.

En sık hata

"Resetleyip devam edelim" — o düğme kanıtı sonsuza dek siler. Doğru sıra: önce emniyet, hemen sonra kanıt. Makineyi güvenli duruma almak ile logları silmek aynı şey değildir; biri korur, diğeri yok eder.

Eğitim çalışmasıdır, resmî olay müdahale prosedürü değildir. Senaryo kurgudur.